

Name :A.Purusothaman

Reg.no:192421405

Subject:Ethical Hacking

Sub.Code:ITA1407

CO4-AT2 ETHICAL HACKING

Vulnerability Assessment Reports

1. TJX Companies Wireless Network Breach, 2005–2007

Executive Summary

The TJX breach demonstrated how weaknesses in wireless security can expose large amounts of payment-card information. Attackers gained unauthorized access through a poorly secured wireless network that used outdated WEP encryption. Inadequate network segmentation, monitoring, and protection of sensitive payment data increased the impact of the compromise.

Key Vulnerabilities

- 1. Weak wireless encryption:** WEP was obsolete and vulnerable to key-recovery attacks.
- 2. Insufficient authentication:** Wireless access was not adequately restricted to authorized users and devices.

3. **Poor network segmentation:** Wireless traffic could reach systems containing payment information.
4. **Inadequate monitoring:** Rogue devices and suspicious wireless activity were not detected quickly.
5. **Payment-data exposure:** Sensitive cardholder data was insufficiently protected while being transmitted and stored.

Recommended Controls

- Replace WEP with **WPA2-Enterprise or WPA3-Enterprise** using AES-based encryption.
- Implement **802.1X authentication** with RADIUS and individual user credentials or certificates.
- Separate guest, corporate, wireless, POS, and cardholder-data networks using VLANs and firewalls.
- Deploy **Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS)** to identify rogue access points and unauthorized connections.
- Encrypt cardholder data in transit and at rest.
- Apply **PCI DSS** requirements for network segmentation, access control, vulnerability management, logging, monitoring, and protection of stored/transmitted cardholder data.
- Conduct regular wireless penetration testing and vulnerability assessments.

Risk

Critical. A compromise of the wireless network could provide attackers with access to payment systems and sensitive customer information.

Conclusion

The TJX incident could have been significantly reduced through modern wireless encryption, strong enterprise authentication, network segmentation, continuous monitoring, and PCI DSS compliance.

2. Lowe's Wireless Network Intrusion, 2003

Executive Summary

The Lowe's incident demonstrated the danger of allowing a local wireless compromise to provide access to centralized corporate systems. Attackers exploited weaknesses in wireless security and attempted to install software capable of capturing customers' credit-card information.

Key Vulnerabilities

- Weak wireless authentication.
- Insufficient isolation between wireless clients and internal systems.
- Inadequate firewall restrictions.
- Poor segmentation of point-of-sale systems.
- Insufficient intrusion detection.

- Weak centralized access management.

Recommended Controls

- Use **WPA2/WPA3-Enterprise with 802.1X** rather than open or weakly protected wireless access.
- Place wireless clients in dedicated VLANs.
- Use firewalls to restrict wireless-to-POS and wireless-to-corporate traffic.
- Place POS systems in a separate protected network with access permitted only from authorized systems.
- Deploy IDS/IPS and WIDS/WIPS.
- Centralize authentication through RADIUS/identity-management systems.
- Apply least-privilege access and monitor administrator activity.
- Encrypt payment information and comply with PCI DSS.

Risk

Critical, because compromise of a single local access point could potentially lead to broader corporate compromise and payment-card theft.

Conclusion

Strong authentication, segmentation, firewall controls, centralized identity management, and continuous intrusion detection would have greatly reduced the attacker's ability to move from the wireless network to sensitive corporate systems.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

Executive Summary

Firesheep demonstrated that users on an open wireless network could capture unencrypted session cookies and impersonate authenticated users. The fundamental weakness was failure to protect the entire authenticated web session with HTTPS.

Key Vulnerabilities

- Open and untrusted wireless networks.
- Unencrypted HTTP traffic after login.
- Session cookies transmitted without adequate protection.
- Lack of HSTS.
- Limited use of VPNs.
- Lack of wireless client isolation.
- Insufficient user awareness.

Recommended Controls

- Enforce **HTTPS for the entire session**, not just the login page.
- Enable **HSTS** and configure secure TLS settings.
- Set cookies with Secure, HttpOnly, and appropriate SameSite attributes.
- Use VPN services for sensitive activity on untrusted networks.
- Enable client isolation on public Wi-Fi.
- Use WPA2/WPA3 security where appropriate, while recognizing that encryption alone does not replace HTTPS.
- Educate users about the risks of public Wi-Fi and suspicious network connections.
- Use MFA for important accounts.

Risk

High, because session hijacking can allow attackers to impersonate authenticated users without knowing their passwords.

Conclusion

Full-session HTTPS, HSTS, secure cookies, MFA, VPN use, client isolation, and user education substantially reduce Firesheep-style attacks.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

Executive Summary

DarkHotel demonstrated how compromised hotel networks can be used to target high-value guests. Attackers could exploit weaknesses in captive portals, software-update mechanisms, DNS, and network monitoring to deliver malware.

Key Vulnerabilities

- Weak guest authentication.
- Insecure captive portals.
- Potential DNS manipulation.
- Insufficient guest-network segmentation.
- Third-party network-management risks.
- Insecure software-update delivery.
- Inadequate malware detection.
- Insufficient monitoring of privileged systems.

Recommended Controls

- Use secure WPA2/WPA3 enterprise infrastructure where practical.
- Protect captive portals with HTTPS and strong authentication.

- Validate DNS integrity and monitor for unauthorized DNS changes.
- Isolate guest devices from hotel administrative and operational networks.
- Apply strict third-party access controls.
- Require digitally signed software updates and verify signatures before installation.
- Deploy endpoint protection and malware detection.
- Monitor privileged administrator accounts.
- Use MFA and least privilege for hotel IT administrators.
- Maintain centralized security logs and security monitoring.

Risk

High/Critical, particularly for executives and government officials carrying sensitive information.

Conclusion

Hotel Wi-Fi should be treated as an untrusted environment. Strong segmentation, secure update mechanisms, DNS protection, endpoint security, and privileged-access monitoring are essential.

5. Marriott Wi-Fi Deauthentication Incident, 2014

Executive Summary

The Marriott incident demonstrated that unauthorized transmission of 802.11 deauthentication frames can disrupt wireless availability. Management frames historically lacked adequate cryptographic protection, allowing attackers to forge frames that caused clients to disconnect.

Key Vulnerabilities

- Unprotected or insufficiently protected management frames.
- Ability to transmit forged deauthentication frames.
- Insufficient wireless intrusion detection.
- Availability risks to guest networks.
- Potential interference with legitimate wireless devices.

Recommended Controls

- Use **Protected Management Frames (PMF/802.11w)**.
- Deploy **WPA3**, which requires PMF.
- Use WIDS/WIPS to detect deauthentication floods and suspicious RF activity.
- Establish acceptable-use policies that prohibit unauthorized interference.
- Monitor wireless channels for abnormal management-frame activity.

- Establish procedures for identifying and responding to RF attacks.
- Ensure security controls comply with applicable laws and regulations.

Risk

Medium to High, depending on the operational importance of the wireless network.

Legal and Compliance Considerations

Unauthorized interference with wireless communications may result in regulatory penalties and legal consequences.

Organizations should ensure that wireless-security monitoring and countermeasures comply with applicable regulations.

Conclusion

PMF and WPA3 provide important protection against forged management frames, while WIDS/WIPS and appropriate policies improve detection and response.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

Executive Summary

The fake Wi-Fi experiment demonstrated the effectiveness of evil-twin attacks. Users often trust familiar SSID names without verifying whether the access point is legitimate.

Key Vulnerabilities

- Excessive trust in SSID names.
- Automatic Wi-Fi reconnection.
- Open wireless networks.
- Fake captive portals.
- Failure to validate certificates.
- Lack of VPN enforcement.
- Insufficient participant awareness.

Recommended Controls

- Disable automatic connection to unknown/open networks.
- Use WPA2/WPA3 Enterprise networks where possible.
- Educate participants to verify official SSIDs.
- Use certificate-based authentication for enterprise wireless.
- Enforce HTTPS and proper certificate validation.
- Require VPN connections for sensitive communications.
- Deploy wireless monitoring to detect rogue access points.
- Provide clear instructions to participants about legitimate networks.

Risk

High, especially at events involving government officials, executives, journalists, or other high-value targets.

Conclusion

SSID names cannot be trusted as proof of network authenticity. Enterprise authentication, certificate validation, VPN use, rogue-AP detection, and user awareness are essential defenses.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

Executive Summary

Officials handling anti-doping and medical information may be targeted while traveling. Hotel and event Wi-Fi networks present significant risks because attackers can operate from nearby locations and attempt to steal credentials or compromise devices.

Key Vulnerabilities

- Use of untrusted public Wi-Fi.
- Credential theft.
- Lack of MFA.
- Weak endpoint security.
- Inadequate VPN configuration.
- Lack of device certificates.
- Insufficient travel-security policies.

- Exposure of sensitive medical information.

Recommended Controls

- Use **MFA** for all sensitive accounts.
- Deploy device certificates and enterprise authentication.
- Use managed devices with endpoint detection and response.
- Require VPN connections on untrusted networks.
- Use WPA2/WPA3-Enterprise on organizational networks.
- Keep operating systems and applications patched.
- Apply strong password and credential-management policies.
- Provide mandatory travel-security training.
- Encrypt sensitive medical information.
- Apply strict access controls based on least privilege.
- Monitor suspicious account and device activity.

Risk

Critical, because compromise could expose credentials, medical information, and confidential organizational data.

Conclusion

A combination of MFA, device certificates, endpoint security, VPN, secure authentication, and travel-security procedures

can significantly reduce risks to officials using hotel and event Wi-Fi.

8. Attempted OPCW Wi-Fi Intrusion, 2018

Executive Summary

The attempted OPCW operation demonstrated that attackers can conduct close-access wireless attacks from outside a facility. Physical proximity to a building may provide sufficient radio access even when attackers cannot enter the premises.

Key Vulnerabilities

- RF signals extending beyond the physical perimeter.
- Potential targeting of enterprise wireless authentication.
- Insufficient rogue-device detection.
- Risk of unauthorized wireless equipment.
- Physical-security weaknesses.

Recommended Controls

- Use **WPA2-Enterprise/WPA3-Enterprise**.
- Implement **802.1X** authentication.
- Use strong EAP methods with validated server certificates.
- Deploy client/device certificates where appropriate.

- Use Network Access Control to verify device compliance.
- Deploy WIDS/WIPS to identify suspicious access points and attack devices.
- Monitor RF activity around sensitive facilities.
- Conduct regular wireless security assessments.
- Integrate wireless alerts with the organization's SOC.
- Use CCTV, security patrols, and physical surveillance around sensitive areas.

Risk

Critical for a high-security organization handling sensitive information.

Conclusion

Wireless security must extend beyond the building's physical perimeter. Strong authentication, certificate validation, WIDS/WIPS, NAC, and physical surveillance provide layered protection.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

Executive Summary

The alleged Australian evil-twin attacks demonstrated how criminals can imitate legitimate airport or public Wi-Fi networks to collect information from users.

Key Vulnerabilities

- SSID impersonation.
- Automatic device connection.
- Fake captive portals.
- User acceptance of suspicious certificate warnings.
- Exposure of personal information.
- Limited rogue-access-point detection.
- Lack of user verification.

Recommended Controls

- Clearly publish official SSIDs through airport signage and official applications.
- Encourage users to disable automatic connection to open networks.
- Deploy wireless intrusion detection to identify unauthorized access points.
- Use WPA2/WPA3-Enterprise for staff networks.
- Require HTTPS and valid TLS certificates.
- Never instruct users to ignore certificate warnings.
- Avoid collecting unnecessary personal information through captive portals.
- Establish staff procedures for identifying and reporting rogue APs.
- Educate passengers about evil-twin attacks.

- Use VPNs for sensitive activity on public networks.

Risk

High, because airport users may include large numbers of travelers accessing email, banking, corporate systems, and personal information.

Conclusion

Airports should combine technical rogue-AP detection with strong public communication and user education. Users should not assume that a familiar SSID is automatically legitimate.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

Executive Summary

The Network Rail incident demonstrated the risk of a legitimate administrator account being misused to modify a public Wi-Fi landing page. The incident highlights the importance of privileged-access management, MFA, third-party security, logging, and change control.

Key Vulnerabilities

- Compromise or misuse of a legitimate administrator account.
- Insufficient privileged-access management.
- Potentially inadequate MFA.
- Third-party supplier-access risks.

- Weak change-management controls.
- Insufficient account monitoring.
- Inadequate logging or alerting.
- Delayed detection or response.

Recommended Controls

Privileged Access Management

- Use **Privileged Access Management (PAM)** for administrator accounts.
- Apply least privilege.
- Use separate administrator accounts rather than shared accounts.
- Implement just-in-time privileged access where practical.
- Review administrator privileges regularly.

Multifactor Authentication

- Require phishing-resistant MFA for privileged accounts.
- Use hardware security keys or strong authenticator-based methods where appropriate.
- Do not allow password-only administrative access.

Captive-Portal Security

- Separate the captive-portal administration system from public Wi-Fi clients.
- Restrict administrative interfaces to authorized management networks.

- Use HTTPS and secure session management.
- Protect administrator sessions with short timeouts and strong authentication.

Third-Party Supplier Access

- Apply contractual security requirements to suppliers.
- Use individual accounts rather than shared credentials.
- Restrict supplier access to only required systems.
- Monitor and log all supplier administrative activity.
- Remove access immediately when it is no longer required.

Logging and Monitoring

- Maintain centralized logs for administrator authentication and configuration changes.
- Alert on unusual login locations, times, and administrative actions.
- Monitor unauthorized modifications to captive-portal content.
- Protect logs against unauthorized modification.

Change Management

- Require documented approval for production changes.
- Use two-person approval for high-risk modifications.
- Maintain version-controlled configurations.

- Regularly compare production systems against approved configurations.

Incident Response

- Immediately disable compromised accounts.
- Preserve authentication, system, and configuration logs.
- Isolate affected systems when necessary.
- Restore the portal from a known-good configuration.
- Investigate the attack path and determine whether other systems were accessed.
- Notify relevant stakeholders and authorities according to applicable requirements.
- Conduct a post-incident review and update controls.

Risk

High/Critical, because compromise of a privileged administrator account can allow attackers to alter public services and potentially provide a pathway to other systems.

Conclusion

The incident illustrates that protecting Wi-Fi is not only about wireless encryption. Administrative identity security is equally important. Strong MFA, PAM, least privilege, supplier controls, centralized logging, change approval, and rapid incident response can substantially reduce the risk of unauthorized changes.

Overall Recommendations

Across all ten cases, the following security controls provide a strong baseline for wireless environments:

Security Area	Recommended Control
Wireless encryption	WPA2-Enterprise or preferably WPA3-Enterprise
Authentication	802.1X with RADIUS and strong EAP methods
Device authentication	Digital certificates where appropriate
Guest access	Separate guest VLAN/network
Network segmentation	Isolate POS, corporate, administrative, and guest networks
Rogue AP protection	WIDS/WIPS
Management frames	Protected Management Frames
Web security	HTTPS everywhere and HSTS
Remote protection	Enterprise VPN on untrusted networks
Account security	MFA, preferably phishing-resistant MFA
Privileged access	PAM and least privilege

Security Area	Recommended Control
Endpoint protection	EDR/anti-malware and regular patching
Monitoring	Centralized logging and continuous security monitoring
Payment information	PCI DSS controls and encryption
Third parties	Restricted, monitored, time-limited access
Physical security	RF monitoring, CCTV, and physical surveillance
User awareness	Security training and clear Wi-Fi verification procedures
Incident response	Tested procedures for wireless and account compromise

Final Conclusion

The ten incidents demonstrate that wireless vulnerabilities can affect **confidentiality, integrity, and availability**. Older encryption such as WEP, weak authentication, flat networks, rogue access points, insecure web sessions, unprotected management frames, compromised administrator accounts, and inadequate monitoring can turn a wireless weakness into a major organizational security incident.

A modern wireless security architecture should therefore use **WPA3-Enterprise, 802.1X, strong EAP authentication, certificate validation, network segmentation, Protected Management Frames, WIDS/WIPS, MFA, PAM, secure HTTPS, VPN protection, endpoint security, centralized logging, and well-tested incident-response procedures.**

Organizations handling payment or sensitive personal information should additionally align their controls with applicable requirements such as **PCI DSS** and relevant privacy and cybersecurity regulations.